TP 3 – Les malwares et les virus informatiques

Objectifs : étudier les différents types de malware et virus et comment s'en protéger.

Exercice 1 – Recherche de définitions

Travail à faire



Q1.1. Rechercher les définitions suivantes :

malware

Logiciel malveillant : tout programme conçu pour nuire à un système informatique, voler ou détruire des données, espionner l'utilisateur ou prendre le contrôle de la machine sans son accord. C'est le terme générique qui regroupe virus, vers, chevaux de Troie, spywares, ransomwares, etc.



virus (informatique)

Programme malveillant qui s'insère dans un fichier ou un programme légitime (l'hôte) et se réplique. Il se propage quand l'utilisateur exécute ou partage le fichier infecté : il a besoin d'une action humaine. Il peut effacer des données, ralentir ou bloquer le système.



ver informatique

Malware qui se propage tout seul à travers les réseaux (failles de sécurité, mails, partages réseau), sans programme hôte et sans action de l'utilisateur. Il peut saturer le réseau et les machines. Ex. : ILOVEYOU, Blaster, WannaCry (ver + ransomware).



cheval de Troie (trojan)

Programme qui se fait passer pour un logiciel légitime (jeu, crack, utilitaire, facture...) mais qui cache une fonction malveillante : porte dérobée (backdoor), installation d'autres malwares, vol de données. Il ne se réplique pas lui-même : c'est l'utilisateur qui l'installe en toute confiance.



spyware

Logiciel espion : il collecte à l'insu de l'utilisateur des informations (sites visités, identifiants, données personnelles ou bancaires) et les envoie à un tiers, souvent à des fins publicitaires ou frauduleuses.



keylogger

Enregistreur de frappe : type de spyware qui enregistre tout ce qui est tapé au clavier (mots de passe, numéros de carte, messages) et le transmet à l'attaquant. Il existe en version logicielle ou matérielle (petit boîtier entre le clavier et le PC).



ransomware (rançongiciel)

Rançongiciel : malware qui chiffre les fichiers de la victime ou bloque l'accès au système, puis exige une rançon (souvent en cryptomonnaie) en échange de la clé de déchiffrement. Ex. : WannaCry, Locky. Payer ne garantit pas de récupérer ses données.



Adware

Publiciel : logiciel qui affiche des publicités intrusives (pop-ups, bannières, redirections). Souvent installé avec un logiciel gratuit, il peut aussi collecter des données de navigation.



rootkit

Ensemble d'outils qui donne à l'attaquant un accès privilégié (administrateur/root) tout en se cachant du système et de l'antivirus (processus, fichiers et connexions masqués). Très difficile à détecter et à supprimer : une réinstallation du système est parfois nécessaire.

Q1.2 Quelles sont les extensions qu'on peut exécuter un programme/un logiciel?

Sous Windows .exe, .msi, .bat, .cmd, .com, .scr, .ps1 (PowerShell), .vbs, .js, .jar, .lnk, .hta

Sous Linux .sh, .bin, .run, .AppImage, .deb, .rpm (surtout : droit d'exécution, chmod +x)

Sous MacOS .app, .dmg, .pkg, .command, .sh, .workflow

Sous Android .apk (et .aab pour la publication)

Sous iOS .ipa

-Quels sont les signes qui montrent qu'un ordinateur a un virus ?

Lenteurs, plantages ou redémarrages inattendus ; pop-ups publicitaires, page d'accueil ou moteur de recherche modifiés ; programmes inconnus qui s'ouvrent seuls ; antivirus désactivé ; fichiers disparus ou chiffrés ; activité réseau ou disque anormale ; mails envoyés à votre insu.

-Avec quels langages on peut créer un virus informatique ?

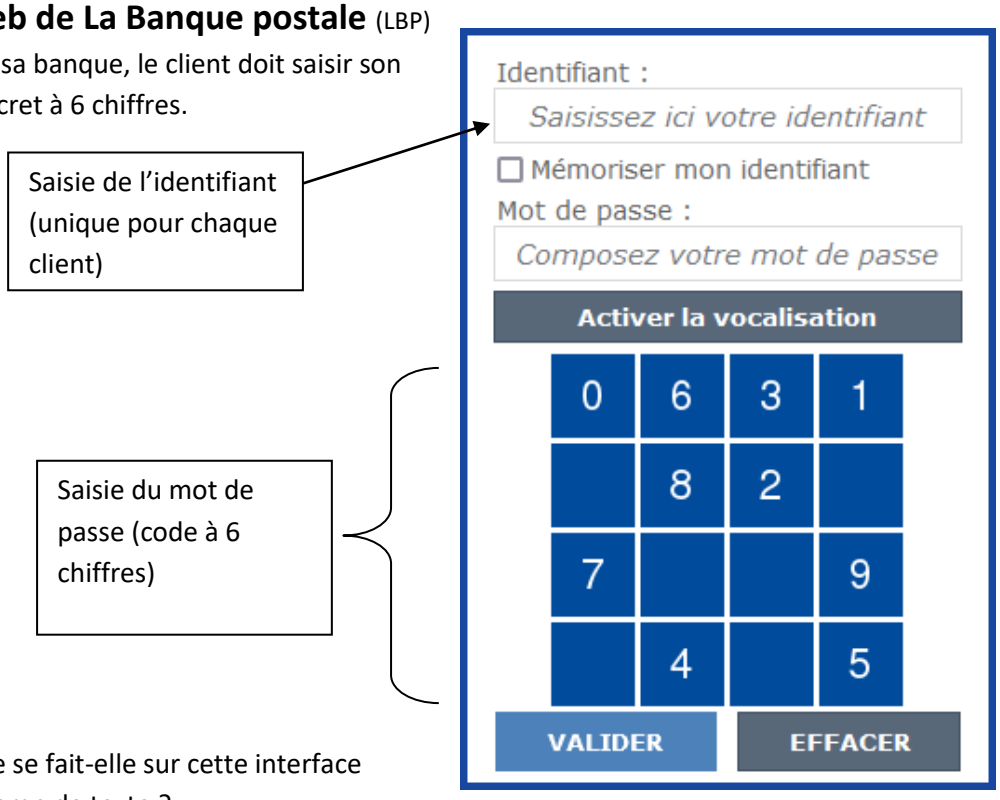
Presque tous : C/C++, assembleur, Python, Java, C#, Go, Rust ; langages de script : Batch, PowerShell, VBScript, JavaScript, Bash ; macros VBA dans Word/Excel.

-Pourquoi on ne peut pas joindre certaines extensions de fichiers dans les mails ? On ne peut pas non plus partager (par Google Drive, Dropbox par ex.) ces extensions.

Ce sont des fichiers exécutables (.exe, .bat, .js, .vbs...) : ils peuvent contenir un malware qui s'exécute dès que le destinataire les ouvre. Messageries et services de partage les bloquent donc pour empêcher la propagation de malwares et protéger les utilisateurs (même ceux qui ne vérifient pas ce qu'ils ouvrent). Les attaquants essaient de contourner en cachant le fichier dans une archive .zip.

Exercice 2 - Le site web de La Banque postale (LBP)

Pour s'identifier au site web de sa banque, le client doit saisir son identifiant ainsi qu'une code secret à 6 chiffres.



Q2.1. Pourquoi la saisie du code se fait-elle sur cette interface spéciale, et non pas dans un champ de texte ?

Pour se protéger des keyloggers : un logiciel espion qui enregistre les touches du clavier ne voit rien, puisque le code est saisi à la souris sur la grille. Cela limite aussi le vol du code par un malware qui surveille le clavier, et l'observation « par-dessus l'épaule » (les chiffres ne sont pas tapés).

Q2.2. La position des chiffres sur la grille est-elle identique à chaque connexion ? Expliquer pourquoi.

Non : la disposition des chiffres est aléatoire à chaque connexion. Ainsi, même si un malware enregistre les clics ou les coordonnées du curseur (screenlogger), ces informations sont inutilisables : à la connexion suivante, les chiffres ne seront plus aux mêmes endroits. Quelqu'un qui observe les gestes ne peut pas non plus rejouer le code.

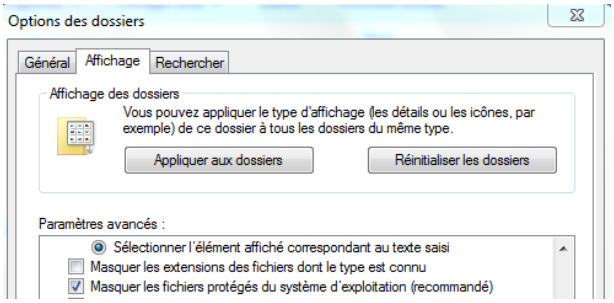
Exercice 3 – Un malware qui se déguise

Travail à faire :

1) Créer un dossier « TP Cybersecurite » dans votre emplacement de travail ;
2) Créer dans ce dossier le dossier « TP Malware »
3) Récupérer le fichier *Matrix.bat* auprès du professeur et le mettre dans le dossier TP Malware :

   Matrix.bat

4) Modifier les options des dossiers afin d'afficher les extensions des fichiers :
   Explorateur de fichiers / touche ALT / Menu Outils / Options des dossiers / onglet Affichage
   Décocher le case « Masquer les extensions des fichiers dont le type est connu »



Capture d'écran sur Windows 7

5) Ouvrir le fichier avec un éditeur de texte comme Notepad++ (clic droit / Edit with Notepad++)
6) Vous pouvez vérifier que ce script est inoffensif :

```
1 @echo off
2 color 02
3 :start
4 echo %random% %random% %random%
5 goto start
```

7) Qu'est-ce qu'un fichier avec l'extension.*bat* ?

   Un fichier batch (traitement par lots) : un fichier texte contenant une suite de commandes Windows exécutées l'une après l'autre par l'interpréteur cmd.exe. C'est un script exécutable.

8) Double cliquer sur le fichier *Matrix.bat* (aucun risque). Qu'est-ce qui s'affiche ?

   Une fenêtre console noire s'ouvre et des suites de nombres aléatoires défilent en continu, en vert (effet « Matrix »). La boucle est infinie : on l'arrête avec Ctrl+C ou en fermant la fenêtre.

9) Fermer le fichier dans l'éditeur de texte (Notepad++) ;
10) Renommer le fichier en « *document ventes.doc.bat* » :

    document ventes.doc.bat

11) Masquer les extensions des fichiers. (C'est l'inverse de la manipulation décrite dans le 4)). Le fichier est affiché ainsi :

    document ventes.doc

12) A quel type de fichiers l'extension *.doc* correspond elle ?

    Un document Microsoft Word (traitement de texte, ancien format) : un fichier de données, censé être sans danger.

13) Si vous cliquez sur le fichier *document ventes.doc,* qu'est-ce qui se passe ?

    Le vrai nom est « document ventes.doc.bat » (le .bat est masqué) : Windows exécute le script et la fenêtre « Matrix » s'ouvre au lieu de Word. On croyait ouvrir un document, on a lancé un programme.

14) Comment un pirate pourrait-il tromper un utilisateur avec un fichier frauduleux ?

    Double extension (facture.pdf.exe) cachée par Windows, nom attractif (facture, CV, colis) et icône trompeuse (Word, PDF), envoyé par mail de phishing ou en téléchargement, parfois dans un .zip. Parade : afficher les extensions et se méfier des pièces jointes inattendues.

15) Essayer d'envoyer ce fichier par mail à quelqu'un.

    Est-ce possible ? Non, en général (pièce jointe bloquée).

    Pourquoi ? Le .bat est un fichier exécutable pouvant contenir un malware : la messagerie bloque cette pièce jointe par mesure de sécurité.

16) Quelles sont les extensions des fichiers qu'on peut exécuter ? (même question que précédent, dans l'objectif de continuité de contenu)

Sous Windows .exe, .msi, .bat, .cmd, .com, .scr, .ps1 (PowerShell), .vbs, .js, .jar, .lnk, .hta

Sous Linux .sh, .bin, .run, .AppImage, .deb, .rpm (surtout : droit d'exécution, chmod +x)

Sous MacOS .app, .dmg, .pkg, .command, .sh, .workflow

Sous Android .apk (et .aab pour la publication)

Sous iOS .ipa

17) Pourquoi on ne peut pas joindre des fichiers ayant certaines extensions dans les mails, et ne peut-on pas non plus les partager via les outils collaboratifs (Google Drive, Dropbox…) ?

Ce sont des fichiers exécutables (.exe, .bat, .js, .vbs...) pouvant contenir un malware qui s'exécute à l'ouverture. Les messageries et outils collaboratifs (Google Drive, Dropbox) les bloquent ou les analysent pour éviter la propagation de malwares à grande échelle. Les attaquants contournent parfois en les cachant dans un .zip.

18) Avec quels langages on peut créer un malware informatique ?

Presque tous : C/C++, assembleur, Python, Java, C#, Go, Rust ; langages de script : Batch, PowerShell, VBScript, JavaScript, Bash ; macros VBA dans Word/Excel.

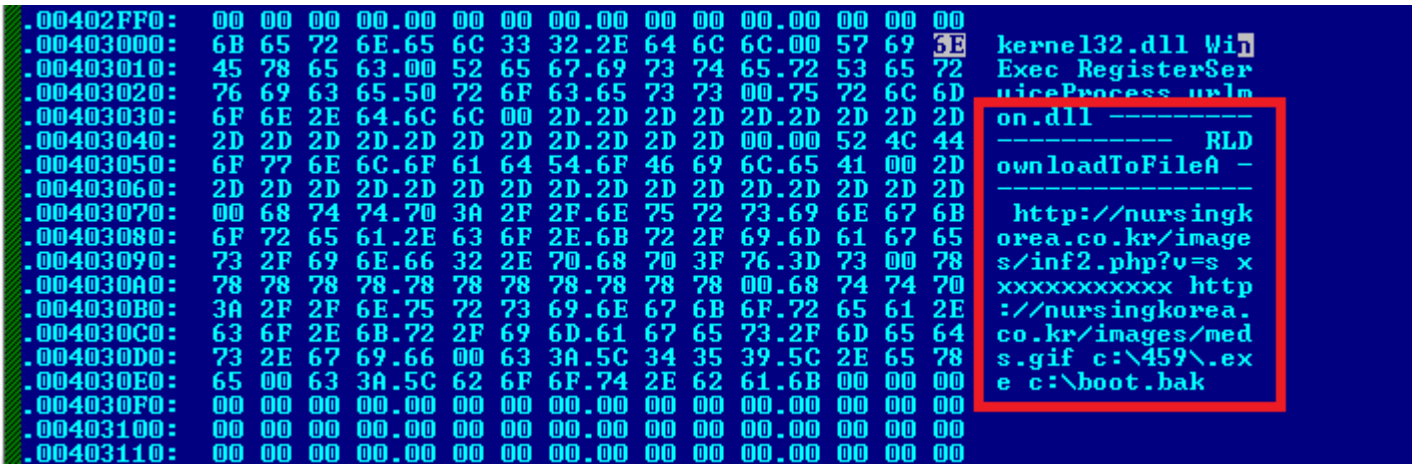
Exercice 4 – Antivirus

Q4.1. Qu'est-ce qu'un antivirus ?

Logiciel de sécurité qui détecte, bloque et supprime (ou met en quarantaine) les logiciels malveillants. Il analyse les fichiers, les programmes en cours d'exécution, les mails et les téléchargements, en temps réel ou à la demande.

Voici un extrait du site de l'éditeur d'anti virus Kaspersky :
(https://www.kaspersky.fr/blog/signature-virus-disinfection/6166/)

> Les bases de données antivirus contiennent ce qu'on appelle des ***signatures***.
> Une ***signature virale*** est une suite continue d'octets qui est commune pour un certain échantillon de malware. Cela signifie qu'elle est présente dans le malware ou le fichier infecté et non dans les fichiers non infectés.



Q4.2. Comment, sur votre PC, un antivirus peut-il détecter un malware ?

- Par signatures : il compare le contenu des fichiers à sa base de signatures virales (suites d'octets propres à un malware connu, comme la suite encadrée en rouge ci-dessus). Si une signature est trouvée, le fichier est jugé infecté.
- Par analyse heuristique : il repère du code ou des instructions suspects, ce qui permet de détecter des variantes de malwares inconnus.
- Par analyse comportementale : il surveille les actions des programmes (chiffrement massif, modification de fichiers système, connexions suspectes), parfois dans une sandbox (environnement isolé).

Q4.3. Que faut-il faire avec son antivirus, régulièrement, afin d'être sûr de détecter tous les malware ? Justifier.

Il faut le mettre à jour régulièrement (base de signatures et moteur), de préférence automatiquement, et lancer des analyses complètes périodiques.
Justification : de nouveaux malwares apparaissent chaque jour et l'antivirus ne reconnaît que ceux dont la signature figure dans sa base ; sans mise à jour, il est aveugle face aux menaces récentes. Aucun antivirus ne garantit une détection à 100 % : il faut aussi de bonnes pratiques.

Exercice 5 – Qu'est-ce qu'un botnet ?



Extrait du site : https://www.avast.com/fr-fr/c-botnet

Un ***botnet*** est un groupe d'ordinateurs liés par un malware et contrôlés par le créateur de ce botnet, que l'on appelle le bot herder, ou maître de botnet. Ces pirates infectent les ordinateurs afin de créer des botnets qu'ils contrôlent comme un groupe pour lancer des cyberattaques de grande ampleur, envoyer des spams et lancer des campagnes de phishing.

Le terme botnet vient de « robot network », c'est-à-dire « réseau de robots ». Les ordinateurs qui composent le botnet sont appelés bots ou ordinateurs zombies. Certains botnets se composent de centaines, voire de milliers d'ordinateurs, ce qui en fait l'une des pires cybermenaces du moment.

Comment créer un botnet ?

Pour créer et utiliser un botnet, le pirate doit mener à bien une attaque en trois phases :

1) infecter les appareils de ses victimes, via un malware
2) faire grandir le botnet en infectant d'autres machines
3) et enfin activer ce botnet.

Que peuvent faire les botnets ?

- Attaques DdoS,
- Campagnes de spam et de phishing ,
- Minage de cryptomonnaie,
- Surveiller les victimes et voler des données personnelles.

Qu.5.1 – Comment se protéger des botnets ?
(voir la page : https://www.avast.com/fr-fr/c-botnet)

- Installer un antivirus à jour et activer le pare-feu.
- Faire les mises à jour du système, du navigateur et des logiciels (pour corriger les failles).
- Ne pas ouvrir de pièces jointes ni de liens suspects (phishing) ; ne pas télécharger depuis des sources douteuses ou piratées.
- Utiliser des mots de passe forts et uniques, la double authentification, et changer les mots de passe par défaut des routeurs, caméras et objets connectés.
- Travailler avec un compte non administrateur au quotidien ; faire des sauvegardes régulières ; sensibiliser les utilisateurs.

Qu.5.2 –Comment savoir si votre ordinateur fait partie d'un botnet, ou si d'une manière générale, il est infecté par un malware ?

- Symptômes : ordinateur lent ou qui chauffe, ventilateur qui s'emballe, processeur ou réseau très sollicités sans raison (minage, DDoS), pop-ups, programmes inconnus, antivirus désactivé.
- Signes externes : des contacts reçoivent des spams venant de vous ; le fournisseur d'accès ou un hébergeur vous alerte.
- Vérifications : examiner les processus (Gestionnaire des tâches), les connexions réseau actives (netstat, Moniteur de ressources) et les programmes lancés au démarrage.
- Analyse : lancer une analyse complète avec un antivirus à jour, complétée par un second outil antimalware ou une analyse hors ligne (support bootable).
- En cas de doute grave : déconnecter la machine du réseau, sauvegarder les données saines puis réinstaller le système.